

Material Suplementar

Dos Estudos em Laboratório à Aplicação Prática em Análise Não Invasiva de Segurança

Anexos Técnicos: scripts, saídas de comandos e evidências coletadas

Matheus Clisman Mariano da Silva

Orientador: Prof. Dr. Carlos Alberto da Silva

Campo Grande, 2026

Este documento é o material suplementar do artigo principal:

“Dos Estudos em Laboratório à Aplicação Prática em Análise Não Invasiva de Segurança”.

Disponível em: https://LINK_DO_ARTIGO_PRINCIPAL

Anexos Técnicos

Os anexos a seguir são suplementares ao corpo principal do artigo. Eles reúnem os scripts, comandos e saídas que geraram as evidências discutidas no texto, preservando a extensão principal do artigo em aproximadamente sete páginas.

Anexo A – Script completo de coleta não invasiva

O script a seguir corresponde ao código principal utilizado para gerar as evidências de coleta HTTP/TLS apresentadas ao longo do artigo.

```
#!/usr/bin/env bash
set -Eeuo pipefail

# =====
# Coleta não invasiva de evidências HTTP/TLS para TCC
```

```

# Alvo: certificados.ufms.br
# Escopo: apenas recursos públicos, sem exploração, sem fuzzing,
# sem brute force, sem enumeração de IDs, sem scanner ativo.
# =====

TARGET_HOST="certificados.ufms.br"
BASE_URL="https://${TARGET_HOST}"
URLS=(
    "https://certificados.ufms.br/"
    "https://certificados.ufms.br/emitir-certificados/index"
    "https://certificados.ufms.br/vendor/cakephp/cakephp/src/Core/functions.php"
)

RUN_ID="$(date -u +%Y%m%dT%H%M%SZ)"
OUT_BASE="evidencias/coleta_${TARGET_HOST}_${RUN_ID}"
mkdir -p "$OUT_BASE"

LOG_FILE="$OUT_BASE/terminal_transcript.log"

# Grava tudo que aparece no terminal também em arquivo
exec > >(tee -a "$LOG_FILE") 2>&1

echo "======"
echo "COLETA NÃO INVASIVA - ${TARGET_HOST}"
echo "======"
echo "Data UTC de início: $(date -u --iso-8601=seconds)"
echo "Data local de início: $(date --iso-8601=seconds)"
echo "Usuário: $(whoami)"
echo "Hostname local: $(hostname)"
echo "Diretório: $(pwd)"
echo "Kernel/SO:"
uname -a
echo

echo "======"
echo "ESCOPO E LIMITAÇÕES"
echo "======"
cat <<'EOF'
Esta coleta é limitada a:
- Requisições HTTP normais com curl.
- Leitura de headers HTTP públicos.
- Download do HTML público da página informada.
- Identificação leve de tecnologia com whatweb -a 1, se disponível.
- Avaliação TLS com testssl --fast, se disponível.
- Consulta TLS básica com openssl s_client, se disponível.

```

Não são realizados:

- Exploração.
- Fuzzing.
- Brute force.
- Enumeração de identificadores.
- SQL injection.
- XSS ativo.
- Directory brute force.
- Active scan do OWASP ZAP.
- Acesso autenticado.

EOF

echo

echo "=====

echo "VERSÕES DAS FERRAMENTAS"

echo "=====

echo "[date]"

date --version 2>/dev/null | head -n 1 || date

echo

echo "[curl]"

curl --version | head -n 2 || true

echo

echo "[openssl]"

openssl version -a 2>/dev/null | head -n 5 || true

echo

echo "[whatweb]"

if command -v whatweb >/dev/null 2>&1; then

whatweb --version 2>&1 | head -n 3 || true

else

echo "whatweb não encontrado"

fi

echo

echo "[testssl]"

if command -v testssl >/dev/null 2>&1; then

command -v testssl

testssl --version 2>&1 | head -n 5 || true

elif command -v testssl.sh >/dev/null 2>&1; then

command -v testssl.sh

testssl.sh --version 2>&1 | head -n 5 || true

else

```

    echo "testssl/testssl.sh não encontrado"
fi
echo

echo "====="
echo "RESOLUÇÃO DNS BÁSICA"
echo "====="
{
    echo "Data UTC: $(date -u --iso-8601=seconds)"
    getent hosts "$TARGET_HOST" || true
} | tee "$OUT_BASE/dns_getent.txt"
echo

echo "====="
echo "COLETA DE HEADERS HTTP"
echo "====="

i=0
for url in "${URLS[@]}"; do
    i=$((i + 1))
    safe_name="$(echo "$url" | sed 's#https\?://##; s#[^A-Za-z0-9._-]#_#g')"
    header_file="$OUT_BASE/${i}_${safe_name}_headers.txt"
    body_file="$OUT_BASE/${i}_${safe_name}_body.html"
    meta_file="$OUT_BASE/${i}_${safe_name}_metadata.txt"

    echo "-----"
    echo "URL: $url"
    echo "Data UTC antes da requisição: $(date -u --iso-8601=seconds)"
    echo "Salvando headers em: $header_file"
    echo "Salvando corpo em: $body_file"
    echo

    {
        echo "URL: $url"
        echo "Data UTC antes: $(date -u --iso-8601=seconds)"
        curl -sS -L \
            -w $'\nCURL_HTTP_CODE=%{http_code}\nCURL_EFFECTIVE_URL=%{url_effective}\n\nCURL_REMOTE_IP=%{remote_ip}\nCURL_TIME_TOTAL=%{time_total}\n' \
            -D "$header_file" \
            -o "$body_file" \
            "$url"
        echo "Data UTC depois: $(date -u --iso-8601=seconds)"
    } | tee "$meta_file"

    echo

```

```

echo "Headers recebidos:"
cat "$header_file"
echo
done

echo "=====
echo "ANÁLISE LOCAL DOS HEADERS COLETADOS"
echo "=====

HEADER_SUMMARY="$OUT_BASE/resumo_headers_seguranca.txt"

{
echo "Resumo de headers de segurança"
echo "Data UTC: $(date -u --iso-8601=seconds)"
echo

for f in "$OUT_BASE"/*_headers.txt; do
echo "-----"
echo "Arquivo: $f"
echo

for h in \
    "strict-transport-security" \
    "content-security-policy" \
    "x-frame-options" \
    "x-content-type-options" \
    "referrer-policy" \
    "permissions-policy" \
    "set-cookie" \
    "cache-control" \
    "pragma" \
    "expires" \
    "server" \
    "x-powered-by"
do
if grep -iq "^${h}:" "$f"; then
echo "[PRESENTE] $h"
grep -i "^${h}:" "$f" || true
else
echo "[AUSENTE] $h"
fi
echo
done
done
} | tee "$HEADER_SUMMARY"

```

```

echo "====="
echo "COLETA DO HTML PÚBLICO DA PÁGINA PRINCIPAL DE EMISSÃO"
echo "====="

INDEX_HTML="$OUT_BASE/index_emitir_certificados.html"
curl -sS -L "https://certificados.ufms.br/emitir-certificados/index" -o "
    $INDEX_HTML"

echo "HTML salvo em: $INDEX_HTML"
echo "Tamanho:"
wc -c "$INDEX_HTML"
echo

echo "Extraindo scripts, CSS, imagens e links relevantes..."
{
    echo "Data UTC: $(date -u --iso-8601=seconds)"
    echo
    echo "[src=]"
    grep -Eo 'src="[^"]+"' "$INDEX_HTML" || true
    echo
    echo "[href=]"
    grep -Eo 'href="[^"]+"' "$INDEX_HTML" || true
    echo
    echo "[Possíveis bibliotecas/tecnologias]"
    grep -Eio "jquery|bootstrap|angular|vue|react|cake|php|laravel|symfony|
        version|\.js|\.css|recaptcha" "$INDEX_HTML" || true
} | tee "$OUT_BASE/html_recursos_extraidos.txt"

echo

echo "====="
echo "DOWNLOAD DE JS/CSS PÚBLICOS REFERENCIADOS NO HTML"
echo "====="

ASSET_DIR="$OUT_BASE/assets_publicos"
mkdir -p "$ASSET_DIR"

# Extraí caminhos relativos internos de src/href que terminam com .js ou .css
grep -Eo '(src|href)="[^"]+\.(js|css)(\[?[^"]*)?' "$INDEX_HTML" \
    | sed -E 's/^(src|href)="//; s/"$//; \
    | grep -v '^https://www.google.com/recaptcha' \
    | sort -u \
    | while read -r asset; do
        # Só baixa recursos do mesmo host ou caminhos relativos

```

```

    if [[ "$asset" =~ ^https?:// ]]; then
        asset_url="$asset"
    elif [[ "$asset" =~ ^/ ]]; then
        asset_url="${BASE_URL}${asset}"
    else
        asset_url="${BASE_URL}/${asset}"
    fi

    asset_name="$(echo "$asset" | sed 's#[/?&=:]#_#g; s#^_#')'"
    echo "Baixando recurso público: $asset_url"
    curl -sS -L -D "$ASSET_DIR/${asset_name}.headers.txt" \
        -o "$ASSET_DIR/${asset_name}" \
        "$asset_url" || true
done

echo
echo "Buscando versões aparentes em JS/CSS baixados..."
{
    echo "Data UTC: $(date -u --iso-8601=seconds)"
    echo
    grep -RInE "jquery|bootstrap|angular|vue|react|cakephp|version|v
        [0-9]+\.[0-9]+|@[0-9]+\.[0-9]+" "$ASSET_DIR" 2>/dev/null || true
} | tee "$OUT_BASE/assets_busca_versoes.txt"

echo

echo "======"
echo "WHATWEB - FINGERPRINT LEVE"
echo "======"

if command -v whatweb >/dev/null 2>&1; then
    whatweb -a 1 "$BASE_URL/" | tee "$OUT_BASE/whatweb_a1.txt"
else
    echo "whatweb não instalado. Pulei esta etapa." | tee "$OUT_BASE/whatweb_a1.
        txt"
fi

echo

echo "======"
echo "TESTSSL - TLS FAST, SE DISPONÍVEL"
echo "======"

if command -v testssl >/dev/null 2>&1; then
    echo "Executando: testssl --fast --warnings batch --color 0 $BASE_URL/"

```

```

testssl --fast --warnings batch --color 0 "$BASE_URL/" | tee "$OUT_BASE/
testssl_fast.txt" || true
elif command -v testssl.sh >/dev/null 2>&1; then
    echo "Executando: testssl.sh --fast --warnings batch --color 0 $BASE_URL/"
    testssl.sh --fast --warnings batch --color 0 "$BASE_URL/" | tee "$OUT_BASE/
testssl_fast.txt" || true
else
    echo "testssl/testssl.sh não encontrado. Pulei esta etapa." | tee "$OUT_BASE/
testssl_fast.txt"
fi

echo

echo "=====
echo "OPENSSL S_CLIENT - CERTIFICADO E TLS BÁSICO"
echo "=====

if command -v openssl >/dev/null 2>&1; then
{
    echo "Data UTC: $(date -u --iso-8601=seconds)"
    echo | openssl s_client -connect "${TARGET_HOST}:443" -servername "
    $TARGET_HOST" -showcerts 2>/dev/null
} | tee "$OUT_BASE/openssl_s_client.txt"

{
    echo "Data UTC: $(date -u --iso-8601=seconds)"
    echo | openssl s_client -connect "${TARGET_HOST}:443" -servername "
    $TARGET_HOST" 2>/dev/null \
    | openssl x509 -noout -subject -issuer -dates -fingerprint -sha256
} | tee "$OUT_BASE/certificado_resumo.txt" || true
else
    echo "openssl não encontrado. Pulei esta etapa." | tee "$OUT_BASE/
openssl_s_client.txt"
fi

echo

echo "=====
echo "GERAÇÃO DE MANIFESTO SHA256"
echo "=====

MANIFEST="$OUT_BASE/SHA256SUMS.txt"

{
    echo "# Manifesto SHA256"

```



```

echo "# Alvo: $TARGET_HOST"
echo "# Data UTC: $(date -u --iso-8601=seconds)"
echo "# Diretório: $OUT_BASE"
echo
} > "$MANIFEST"

find "$OUT_BASE" -type f ! -name "SHA256SUMS.txt" -print0 \
| sort -z \
| xargs -0 sha256sum >> "$MANIFEST"

cat "$MANIFEST"

echo

echo "====="
echo "PACOTE FINAL TAR.GZ"
echo "====="

TAR_FILE="${OUT_BASE}.tar.gz"
tar -czf "$TAR_FILE" "$OUT_BASE"

sha256sum "$TAR_FILE" | tee "${TAR_FILE}.sha256"

echo
echo "Data UTC de fim: $(date -u --iso-8601=seconds)"
echo "Data local de fim: $(date --iso-8601=seconds)"
echo
echo "Arquivos gerados:"
echo "- Diretório: $OUT_BASE"
echo "- Pacote: $TAR_FILE"
echo "- Hash do pacote: ${TAR_FILE}.sha256"
echo
echo "Coleta concluída."

```

Anexo B – Script de verificação rápida de headers

O script abaixo foi utilizado como verificação objetiva dos cabeçalhos e das flags do cookie de sessão.

```

#!/bin/bash

URL="https://certificados.ufms.br/"
OUT="evidencias/headers_verificacao.txt"

```

```

mkdir -p evidencias

echo "[*] Coletando headers de $URL"
curl -s -D "$OUT" -o /dev/null "$URL"

echo
echo "===== HEADERS COLETADOS ====="
cat "$OUT"

echo
echo "===== VERIFICAÇÃO DOS CABEÇALHOS ====="

check_header() {
    HEADER="$1"
    if grep -iq "^$HEADER:" "$OUT"; then
        echo "[PRESENTE] $HEADER"
    else
        echo "[AUSENTE] $HEADER"
    fi
}

check_header "Strict-Transport-Security"
check_header "Content-Security-Policy"
check_header "X-Frame-Options"
check_header "X-Content-Type-Options"
check_header "Referrer-Policy"
check_header "Permissions-Policy"

echo
echo "===== COOKIES ====="
grep -i "^set-cookie:" "$OUT"

echo
echo "===== VERIFICAÇÃO DE FLAGS DO COOKIE ====="

if grep -i "^set-cookie:" "$OUT" | grep -iq "HttpOnly"; then
    echo "[PRESENTE] HttpOnly"
else
    echo "[AUSENTE] HttpOnly"
fi

if grep -i "^set-cookie:" "$OUT" | grep -iq "Secure"; then
    echo "[PRESENTE] Secure"
else

```

```

    echo "[AUSENTE] Secure"
fi

if grep -i "^set-cookie:" "$OUT" | grep -iq "SameSite"; then
    echo "[PRESENTE] SameSite"
else
    echo "[AUSENTE] SameSite"
fi

```

Anexo C – Comandos e saídas centrais da verificação

Os dois primeiros blocos a seguir sintetizam saídas extraídas diretamente das evidências coletadas. O terceiro bloco registra os comandos centrais usados na validação complementar de sessão e logout, sempre com valores sensíveis redigidos.

```

HTTP/2 200
content-type: text/html; charset=UTF-8
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate
pragma: no-cache
set-cookie: CAKEPHP=<COOKIE_REDACTED>; path=/; HttpOnly
strict-transport-security: max-age=31536000; includeSubDomains

```

```

[PRESENTE] Strict-Transport-Security
[AUSENTE] Content-Security-Policy
[AUSENTE] X-Frame-Options
[AUSENTE] X-Content-Type-Options
[AUSENTE] Referrer-Policy
[AUSENTE] Permissions-Policy

[PRESENTE] HttpOnly
[AUSENTE] Secure
[AUSENTE] SameSite

```

```

curl -s -b "CAKEPHP=<COOKIE_REDACTED>" "https://certificados.ufms.br/home"

curl -sS -o /dev/null -w "%{http_code}\n" \
    -b "CAKEPHP=<COOKIE_REDACTED>" \
    https://certificados.ufms.br/home

302

```

Anexo D – Código da prova de conceito de clickjacking

O código abaixo corresponde ao artefato local utilizado para verificar o carregamento da página pública do SICERT em *iframe*.

```
<!DOCTYPE html>
<html>
<head>
  <title>PoC Clickjacking - SICERT</title>
  <style>
    iframe {
      width: 100%;
      height: 700px;
      opacity: 0.5;
    }
  </style>
</head>
<body>
  <h1>Site SICERT sendo executado dentro de um iframe (Clickjacking)</h1>
  <iframe src="https://certificados.ufms.br/"></iframe>
</body>
</html>
```

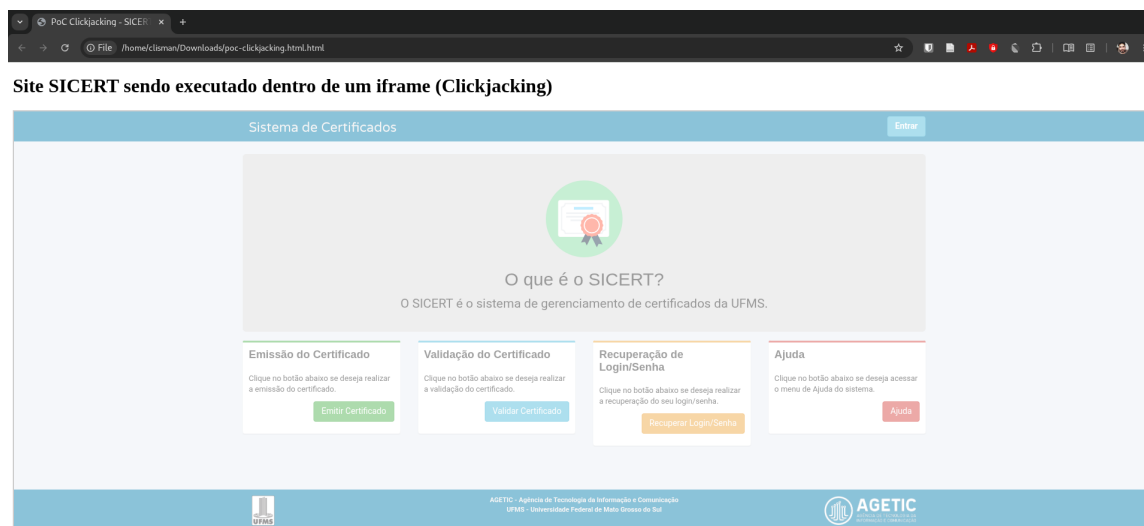


Figura 1: Captura da prova de conceito local mostrando o SICERT carregado dentro de um iframe.

Anexo E – Capturas complementares do SecurityHeaders.com

As figuras a seguir foram utilizadas apenas como validação visual suplementar dos resultados obtidos pela coleta própria com `curl` e pelos scripts locais apresentados nos anexos anteriores.

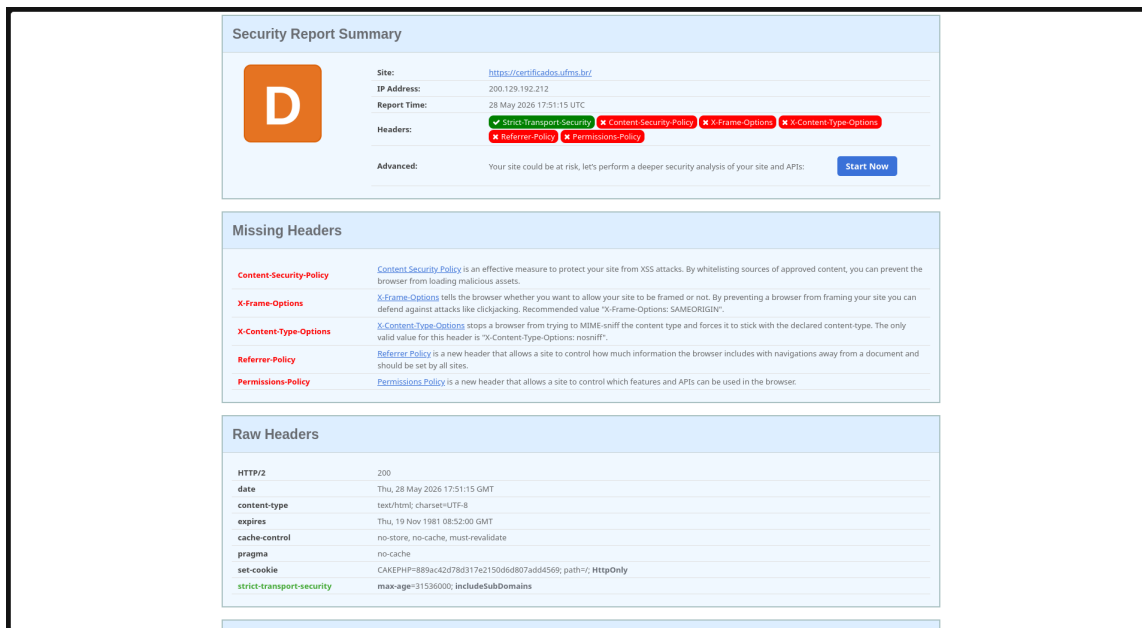


Figura 2: Resumo do SecurityHeaders.com para o domínio analisado, com nota D e destaque para HSTS presente e cabeçalhos de hardening ausentes.

Raw Headers	
HTTP/2	200
date	Thu, 28 May 2026 17:51:15 GMT
content-type	text/html; charset=UTF-8
expires	Thu, 19 Nov 1981 08:52:00 GMT
cache-control	no-store, no-cache, must-revalidate
pragma	no-cache
set-cookie	CAKEPHP=889ac42d78d317e2150d6d807add4569; path=/; HttpOnly
strict-transport-security	max-age=31536000; includeSubDomains

Figura 3: Seção Raw Headers do SecurityHeaders.com, coerente com os cabeçalhos obtidos pela coleta própria.

Anexo F – Trechos complementares de fingerprint e TLS

```
https://certificados.ufms.br/ [200 OK] Cookies[CAKEPHP],  
HttpOnly[CAKEPHP], PHPCake,
```

Strict-Transport-Security[max-age=31536000; includeSubDomains]

subject=C=BR, ST=MATO GROSSO DO SUL, L=CAMPO GRANDE,
O=FUNDACAO UNIVERSIDADE FEDERAL DE MATO GROSSO DO SUL, CN=*.ufms.br
issuer=C=BE, O=GlobalSign nv-sa, CN=GlobalSign RSA OV SSL CA 2018
notBefore=Sep 8 13:36:02 2025 GMT
notAfter=Oct 10 13:36:01 2026 GMT
sha256 Fingerprint=5A:F5:09:2F:4A:32:21:1B:E3:9E:7C:57:45:E5:B5:08:83:49:E5:22:
F9:0B:3D:97:C9:D4:44:05:8C:D0:FA:2A